



**UNIVERSIDAD DISTRITAL
FRANCISCO JOSÉ DE CALDAS**
Acreditación Institucional en Alta Calidad



Sísifo- Gestión de Roles de usuarios y Programación

Informe de seguridad

OATI - 2026



<https://tuleap.portaloas.udistrital.edu.co/plugins/tracker/?aid=81595>

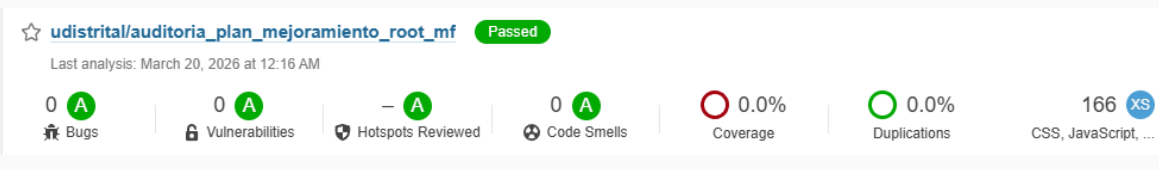
<https://pruebassisifomicroclientes.portaloas.udistrital.edu.co/>

Pruebas de Calidad

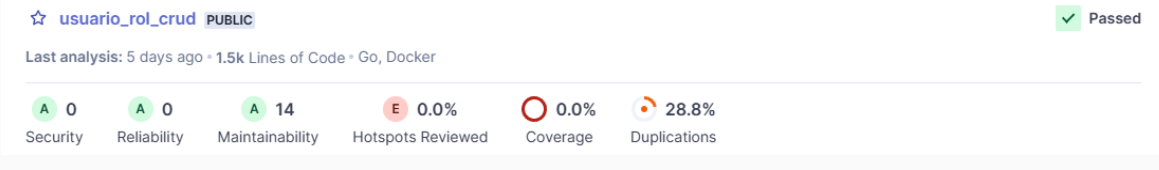
Análisis estático de código – SonarQube

SonarQube™ es un software open source que permite hacer análisis estático del código y obtener métricas que permiten mejorar la calidad del código y descubrir evidencias de los problemas existentes en el código. (<https://www.bitegarden.com/analisis-estatico-del-codigo-con-sonarqube>)

Microcliente:

Repositorio Cliente	https://github.com/udistrital/auditoria_plan_mejoramiento_root_mf
Análisis SonarQube	Aauditoria_plan_mejoramiento_root_mf
	
Observaciones: La revisión no arroja observaciones importantes y pasa el análisis, sin embargo, se debe <u>actualizar a la nueva versión del SonarQube</u> según los lineamientos.	

Crud:

Repositorio	https://github.com/udistrital/usuario_rol_crud
Análisis SonarQube	usuario_rol_crud
	
Observaciones: La revisión no arroja observaciones importantes y pasa el análisis del Sonar	



Microcliente:

Repositorio Cliente	https://github.com/udistrital/usuario_rol_mf
Análisis SonarQube	usuario_rol_mf
☆ usuario_rol_mf PUBLIC Last analysis: 4 days ago • 2.2k Lines of Code • TypeScript, HTML, ... A 0 Security D 2 Reliability A 17 Maintainability A — Hotspots Reviewed 0.0% Coverage 0.0% Duplications Failed	
Observaciones: El código no paso el análisis del SonarQube por lo tanto se deben hacer correcciones en el código	
▼ Type Bug 2 Vulnerability 0 Code Smell 17 ▼ Severity ? High 2 Medium 14 Low 3	
Se deben revisar los Bug y code smell, enfocandose en los de severidad “High” y “Medium”	

Mid:

Repositorio	https://github.com/udistrital/plan_anual_auditoria_mid
Análisis SonarQube	plan_anual_auditoria_mid
☆ plan_anual_auditoria_mid PUBLIC Project's Main Branch is not analyzed yet. Configure analysis	
Observaciones: Se debe actualizar a la nueva versión del SonarQube según los lineamientos.	



Microcliente:

Repositorio Cliente	https://github.com/udistrital/plan_anual_auditoria_mf								
Análisis SonarQube	plan_anual_auditoria_mf								
☆ plan_anual_auditoria_mf PUBLIC Last analysis: 1 hour ago • 24k Lines of Code • TypeScript, HTML, ... A 0 D 14 A 441 E 0.0% 0.0% 22.7% Security Reliability Maintainability Hotspots Reviewed Coverage Duplications									
Observaciones: El código no paso el análisis del SonarQube por lo tanto se deben hacer correcciones en el código									
<table><thead><tr><th>Type</th><th>Severity</th></tr></thead><tbody><tr><td>Bug</td><td>High</td></tr><tr><td>Vulnerability</td><td>Medium</td></tr><tr><td>Code Smell</td><td>Low</td></tr></tbody></table>		Type	Severity	Bug	High	Vulnerability	Medium	Code Smell	Low
Type	Severity								
Bug	High								
Vulnerability	Medium								
Code Smell	Low								
Se deben revisar los Bug y code smell, enfocandose en los de severidad “High” y “Medium”									

Crud:

Repositorio	https://github.com/udistrital/plan_anual_auditoria_crud								
Análisis SonarQube	plan_anual_auditoria_crud								
☆ plan_anual_auditoria_crud PUBLIC Last analysis: 7 days ago • 6.5k Lines of Code • TypeScript A 0 C 3 A 26 E 0.0% 0.0% 9.9% Security Reliability Maintainability Hotspots Reviewed Coverage Duplications									
Observaciones: El código no paso el análisis del SonarQube por lo tanto se deben hacer correcciones en el código									
<table><thead><tr><th>Type</th><th>Severity</th></tr></thead><tbody><tr><td>Bug</td><td>High</td></tr><tr><td>Vulnerability</td><td>Medium</td></tr><tr><td>Code Smell</td><td>Low</td></tr></tbody></table>		Type	Severity	Bug	High	Vulnerability	Medium	Code Smell	Low
Type	Severity								
Bug	High								
Vulnerability	Medium								
Code Smell	Low								
Se deben revisar los Bug y code smell, enfocandose en los de severidad “High” y “Medium”									



Mid:

Repositorio	https://github.com/udistrital/plantillas_mid
Análisis SonarQube	plantillas_mid
☆ udistrital/plantillas_mid Passed Last analysis: January 17, 2025 at 8:41 PM 0 A 0 A — A 1 A 0.0% 3.4% 574 XS Bugs Vulnerabilities Hotspots Reviewed Code Smells Coverage Duplications Go	
Observaciones: La revisión no arroja observaciones importantes y pasa el análisis, sin embargo, se debe <u>actualizar a la nueva versión del SonarQube</u> según los lineamientos.	

Renderizado plantillas:

Repositorio	https://github.com/udistrital/renderizado_plantillas_html
Análisis SonarQube	renderizado_plantillas_html
☆ udistrital/renderizado_plantillas_html Passed Last analysis: March 20, 2026 at 1:13 AM 0 A 0 A 0.0% E 4 A 0.0% 0.0% 131 XS Bugs Vulnerabilities Hotspots Reviewed Code Smells Coverage Duplications Python	
Observaciones: La revisión no arroja observaciones importantes y pasa el análisis, sin embargo, se debe <u>actualizar a la nueva versión del SonarQube</u> según los lineamientos.	



GitHub Alerts

auditoria_plan_mejoramiento_root_mf

Repositorio	https://github.com/udistrital/auditoria_plan_mejoramiento_root_mf/security/dependabot																								
Dependabot alerts: Se lista un total de 19 alertas abiertas: 10 High, 6 Moderate y 3 low. Se debe revisar y actualizar la versión de las dependencias que se encuentran en la lista. <table><tbody><tr><td>@angular/core</td><td>3</td></tr><tr><td>@angular/common</td><td>1</td></tr><tr><td>flatted</td><td>1</td></tr><tr><td>immutable</td><td>1</td></tr><tr><td>lodash</td><td>1</td></tr><tr><td>minimatch</td><td>1</td></tr><tr><td>picomatch</td><td>1</td></tr><tr><td>serialize-javascript</td><td>1</td></tr></tbody></table><table><tbody><tr><td>Critical</td><td>0</td></tr><tr><td>High</td><td>10</td></tr><tr><td>Moderate</td><td>6</td></tr><tr><td>Low</td><td>3</td></tr></tbody></table>		@angular/core	3	@angular/common	1	flatted	1	immutable	1	lodash	1	minimatch	1	picomatch	1	serialize-javascript	1	Critical	0	High	10	Moderate	6	Low	3
@angular/core	3																								
@angular/common	1																								
flatted	1																								
immutable	1																								
lodash	1																								
minimatch	1																								
picomatch	1																								
serialize-javascript	1																								
Critical	0																								
High	10																								
Moderate	6																								
Low	3																								

usuario_rol_mf

Repositorio	https://github.com/udistrital/usuario_rol_mf/security/dependabot																		
Dependabot alerts: Se lista un total de 12 alertas abiertas: 10 High, 6 Moderate y 3 low. Se debe revisar y actualizar la versión de las dependencias que se encuentran en la lista. <table><tbody><tr><td>hono</td><td>6</td></tr><tr><td>vite</td><td>3</td></tr><tr><td>@hono/node-server</td><td>1</td></tr><tr><td>@tootallnate/once</td><td>1</td></tr><tr><td>follow-redirects</td><td>1</td></tr></tbody></table><table><tbody><tr><td>Critical</td><td>0</td></tr><tr><td>High</td><td>2</td></tr><tr><td>Moderate</td><td>9</td></tr><tr><td>Low</td><td>1</td></tr></tbody></table>		hono	6	vite	3	@hono/node-server	1	@tootallnate/once	1	follow-redirects	1	Critical	0	High	2	Moderate	9	Low	1
hono	6																		
vite	3																		
@hono/node-server	1																		
@tootallnate/once	1																		
follow-redirects	1																		
Critical	0																		
High	2																		
Moderate	9																		
Low	1																		



plan_anual_auditoria_mf

Repositorio	https://github.com/udistrital/plan_anual_auditoria_mf/security/dependabot																								
Dependabot alerts: Se lista un total de 14 alertas abiertas: 9 High, 4 Moderate y 1 low. Se debe revisar y actualizar la versión de las dependencias que se encuentran en la lista. <table><tbody><tr><td>@angular/compiler</td><td>3</td></tr><tr><td>@angular/core</td><td>3</td></tr><tr><td>lodash</td><td>2</td></tr><tr><td>lodash-es</td><td>2</td></tr><tr><td>@angular/common</td><td>1</td></tr><tr><td>follow-redirects</td><td>1</td></tr><tr><td>quill</td><td>1</td></tr><tr><td>vite</td><td>1</td></tr></tbody></table><table><tbody><tr><td>Critical</td><td>0</td></tr><tr><td>High</td><td>9</td></tr><tr><td>Moderate</td><td>4</td></tr><tr><td>Low</td><td>1</td></tr></tbody></table>		@angular/compiler	3	@angular/core	3	lodash	2	lodash-es	2	@angular/common	1	follow-redirects	1	quill	1	vite	1	Critical	0	High	9	Moderate	4	Low	1
@angular/compiler	3																								
@angular/core	3																								
lodash	2																								
lodash-es	2																								
@angular/common	1																								
follow-redirects	1																								
quill	1																								
vite	1																								
Critical	0																								
High	9																								
Moderate	4																								
Low	1																								

usuario_rol_crud

Repositorio	https://github.com/udistrital/usuario_rol_crud/security/dependabot														
Dependabot alerts: Se lista un total de 14 alertas abiertas: 9 High, 4 Moderate y 1 low. Se debe revisar y actualizar la versión de las dependencias que se encuentran en la lista. <table><tbody><tr><td>github.com/prometheus/client_golang</td><td>1</td></tr><tr><td>g</td><td></td></tr><tr><td>google.golang.org/grpc</td><td>1</td></tr></tbody></table><table><tbody><tr><td>Critical</td><td>1</td></tr><tr><td>High</td><td>1</td></tr><tr><td>Moderate</td><td>0</td></tr><tr><td>Low</td><td>0</td></tr></tbody></table>		github.com/prometheus/client_golang	1	g		google.golang.org/grpc	1	Critical	1	High	1	Moderate	0	Low	0
github.com/prometheus/client_golang	1														
g															
google.golang.org/grpc	1														
Critical	1														
High	1														
Moderate	0														
Low	0														



plan_anual_auditoria_crud

Repositorio	https://github.com/udistrital/plan_anual_auditoria_crud/security/dependabot
Dependabot alerts: Se lista un total de 3 alertas abiertas: 3 Moderate. Se debe revisar y actualizar la versión de las dependencias que se encuentran en la lista. @nestjs/core2 fast-xml-parser1 Critical0 High0 Moderate3 Low0	

plan_anual_auditoria_mid

Repositorio	https://github.com/udistrital/plan_anual_auditoria_mid/security/dependabot
Dependabot alerts: Se lista un total de 13 alertas abiertas: 8 High, 4 Moderate y 1 Low Se debe revisar y actualizar la versión de las dependencias que se encuentran en la lista. minimatch7 brace-expansion2 flatted1 follow-redirects1 picomatch1 qs1 Critical0 High8 Moderate4 Low1	



Pruebas de seguridad

Revisión manual de funcionalidades del aplicativo

Se realizó una exploración manual del módulo evaluado mediante la navegación directa por las funcionalidades disponibles en la interfaz del aplicativo. Como resultado de esta revisión no se evidenciaron fallas de seguridad ni comportamientos irregulares en las funcionalidades evaluadas, observándose un funcionamiento acorde con el flujo esperado del sistema.

Seguridad a nivel de cabeceras: Security Headers

[Resultados Scan Security Headers](#)

Durante el análisis de seguridad de las cabeceras HTTP del aplicativo web se evidenció la ausencia de encabezados de seguridad recomendados para aplicaciones web modernas. La ausencia de estos mecanismos reduce la capacidad del navegador para aplicar controles de seguridad adicionales, lo que podría facilitar ataques como clickjacking, ejecución de contenido no confiable, filtración de información de navegación o interpretación incorrecta de tipos de contenido.

Se recomienda implementar estos encabezados para fortalecer la protección del aplicativo frente a ataques basados en el navegador.



Security Headers

by snyk

Scan your site now

☐ Hide results ☒ Follow redirects

Security Report Summary



Site:	https://pruebassisifomicroclientes.portal.udo.edu.co/
IP Address:	54.230.114.113
Report Time:	23 Apr 2026 20:24:04 UTC
Headers:	✖ Strict-Transport-Security ✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options ✖ Referrer-Policy ✖ Permissions-Policy
Advanced:	Ouch, you should work on your security posture immediately. Start Now



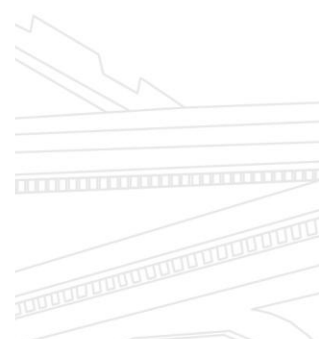
```
> shcheck.py - santoru .....  
Simple tool to check security headers on a webserver  
[*] Analyzing headers of https://pruebassisifomicroclientes.portaloas.udistrital.edu.co/  
[*] Effective URL: https://pruebassisifomicroclientes.portaloas.udistrital.edu.co/  
[!] Missing security header: X-Frame-Options  
[!] Missing security header: X-Content-Type-Options  
[!] Missing security header: Strict-Transport-Security  
[!] Missing security header: Content-Security-Policy  
[!] Missing security header: Referrer-Policy  
[!] Missing security header: Permissions-Policy  
[!] Missing security header: Cross-Origin-Embedder-Policy  
[!] Missing security header: Cross-Origin-Resource-Policy  
[!] Missing security header: Cross-Origin-Opener-Policy  
[!] Headers analyzed for https://pruebassisifomicroclientes.portaloas.udistrital.edu.co/  
[+] There are 0 security headers  
[-] There are not 9 security headers
```

Análisis automatizado de seguridad con OWASP ZAP

El análisis realizado con OWASP ZAP evidenció múltiples debilidades relacionadas principalmente con la configuración de cabeceras de seguridad HTTP y políticas de seguridad de contenido (CSP). Se identificaron directivas CSP incompletas o permisivas, la habilitación de unsafe-inline y unsafe-eval, lo cual reduce la efectividad de la protección frente a ataques como Cross-Site Scripting (XSS). Asimismo, se detectó la ausencia de cabeceras clave como Strict-Transport-Security (HSTS), X-Content-Type-Options y mecanismos anti-clickjacking.

Adicionalmente, se encontraron configuraciones que podrían facilitar la exposición de información sensible o el uso indebido de recursos externos, como la inclusión de archivos JavaScript desde dominios externos sin controles adecuados y la divulgación de versiones del servidor en las respuestas HTTP. También se reportaron aspectos informativos como la exposición de timestamps en formato Unix.

- 📁 Alerts (16)
 - > 🚩 CSP: Failure to Define Directive with No Fallback (2)
 - > 🚩 CSP: Wildcard Directive (2)
 - > 🚩 CSP: script-src unsafe-eval (2)
 - > 🚩 CSP: script-src unsafe-inline (2)
 - > 🚩 CSP: style-src unsafe-inline (2)
 - > 🚩 Cross-Domain Misconfiguration
 - > 🚩 Missing Anti-clickjacking Header (2)
 - > 🚩 Cross-Domain JavaScript Source File Inclusion (10)
 - > 🚩 Server Leaks Version Information via "Server" HTTP Response Header Field (4)
 - > 🚩 Strict-Transport-Security Header Not Set (4)
 - > 🚩 Timestamp Disclosure - Unix (218)
 - > 🚩 X-Content-Type-Options Header Missing (4)
 - > 🚩 ZAP is Out of Date (2)
 - > 📄 Information Disclosure - Suspicious Comments (2)
 - > 📄 Modern Web Application (2)
 - > 📄 Re-examine Cache-control Directives (2)





Enumeración de recursos

Se realizó un proceso de enumeración y descubrimiento de recursos ocultos en el aplicativo web utilizando la herramienta de *fuzzing* **dirb**, con el fin de identificar endpoints no documentados, archivos expuestos o funcionalidades accesibles que no se encuentran enlazadas directamente en la interfaz de la aplicación y no se encontraron hallazgos de seguridad.

```
DIRB v2.22
By The Dark Raver

START_TIME: Thu Apr 30 11:01:59 2026
URL_BASE: https://pruebassisifomicroclientes.portaloas.udistrital.edu.co/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

— Scanning URL: https://pruebassisifomicroclientes.portaloas.udistrital.edu.co/ —
+ https://pruebassisifomicroclientes.portaloas.udistrital.edu.co/favicon.ico (CODE:200|SIZE:10335)

END_TIME: Thu Apr 30 11:14:12 2026
DOWNLOADED: 4612 - FOUND: 1
```

Testssl

El análisis de la configuración TLS mediante testssl.sh evidenció una implementación adecuada de protocolos y suites criptográficas. El sistema soporta versiones seguras como TLS 1.2 y TLS 1.3. Asimismo, no se detectó el uso de suites de cifrado débiles o vulnerables (como RC4, DES, 3DES o cifrados sin autenticación), y se confirma la implementación de cifrados modernos tipo AEAD con Forward Secrecy, lo que garantiza la confidencialidad de las comunicaciones.

```
Testing protocols via sockets except NPN+ALPN

SSLv2      not offered (OK)
SSLv3      not offered (OK)
TLS 1      not offered
TLS 1.1    not offered
TLS 1.2    offered (OK)
TLS 1.3    offered (OK): final
QUIC       not offered (but UDP connection succeeded)
NPN/SPDY   not offered
ALPN/HTTP2 h2, http/1.1 (offered)

Testing cipher categories

NULL ciphers (no encryption)      not offered (OK)
Anonymous NULL Ciphers (no authentication) not offered (OK)
Export ciphers (w/o ADH+NULL)     not offered (OK)
LOW: 64 Bit + DES, RC[2,4], MD5 (w/o export) not offered (OK)
Triple DES Ciphers / IDEA         not offered
Obsoleted CBC ciphers (AES, ARIA etc.) not offered
Strong encryption (AEAD ciphers) with no FS not offered
Forward Secrecy strong encryption (AEAD ciphers) offered (OK)
```



UNIVERSIDAD DISTRITAL
FRANCISCO JOSÉ DE CALDAS
Acreditación Institucional en Alta Calidad

www.udistrital.edu.co

